AI THREAT LAB

Bezpieczne audyty offline, przejrzyste raporty i doradcze analizy AI

Raport Analizy Bezpieczeństwa

PROJEKT: Sklep Internetowy — Backend API

`Lokalizacja: Sklep Internetowy — Backend API`

Projekt:	Sklep Internetowy — Backend API
Ścieżka celu:	Sklep Internetowy — Backend API
Data analizy:	2026-10-21 07:23 UTC
Status przebiegu:	CANDIDATE_FINDINGS
Interpretacja AI:	Google Gemini (gemini-2.5-flash)
Zakres analizy:	Statyczna analiza offline

Ważna informacja o zakresie analizy

Niniejszy raport zawiera wyniki automatycznej, statycznej analizy bezpieczeństwa wykonanej w bezpiecznym trybie offline. Wszelkie wykryte problemy stanowią kandydatów do weryfikacji i wymagają sprawdzenia kontekstu przez programistę. Raport nie stanowi pełnego audytu bezpieczeństwa, testu penetracyjnego ani gwarancji braku innych podatności.

Podsumowanie dla kierownictwa i użytkownika

W projekcie wykryto łącznie 3 potencjalnych problemów bezpieczeństwa (P1: 1, P2: 1, P3: 1). Wszystkie wykrycia mają charakter kandydatów wymagających weryfikacji. Zaleca się priorytetowe zbadanie problemów P1 przed wdrożeniem produkcyjnym.

POTENCJALNE ZAGROŻENIA	STATUS AUDYTU	LIMIT PLIKÓW	OGRANICZENIA ZAKRESU
3	KOMPLETNY	W NORMIE	3

Szczegółowe opisy wykrytych zagrożeń

Zagrożenie nr 1: Obserwacja audytowa (unspecified)

Wysoki priorytet (P1)

Status ustalenia: Kandydat do weryfikacji | Lokalizacja: src/tasks/exporter.py

Co wykryto?

Obserwacja audytowa (unspecified) — lokalizacja: src/tasks/exporter.py. Dowód:

Dlaczego może to być niebezpieczne?

Analizator zgłosił obserwację dla reguły `unspecified` na podstawie dowodu: Wymaga przeglądu przez inżyniera w celu oceny wpływu w kontekście docelowego systemu.

Fragment kodu źródłowego

Kod źródłowy niedostępny lokalnie lub brak dostępu do pliku.

Co należy sprawdzić?

Sprawdź, czy dane wejściowe przekazywane do tej operacji mogą pochodzić z zewnętrznych źródeł i czy są rygorystycznie walidowane.

Jak naprawić problem?

Zastąp wywołanie shell=True przekazaniem listy argumentów: subprocess.run(['tar', '-czf', archive, path], check=True, shell=False).

Jak zweryfikować naprawę?

Zastosuj zalecenie (Zastąp wywołanie shell=True przekazaniem listy argumentów: subprocess.run(['tar', '-czf', archive, path], check=True, shell=False).) i ponownie uruchom kontrolę `ai-threat-lab`.

Ograniczenia analizy

Statyczna obserwacja częściowa; nie stanowi potwierdzonej podatności bez weryfikacji kontekstu.

Interpretacja AI (Google Gemini):

Zagrożenie nr 2: Obserwacja audytowa (unspecified)

Średni priorytet (P2)

Status ustalenia: Kandydat do weryfikacji | Lokalizacja: src/config/integrations.py

Co wykryto?

Obserwacja audytowa (unspecified) — lokalizacja: src/config/integrations.py. Dowód:

Dlaczego może to być niebezpieczne?

Analizator zgłosił obserwację dla reguły `unspecified` na podstawie dowodu: Wymaga przeglądu przez inżyniera w celu oceny wpływu w kontekście docelowego systemu.

Fragment kodu źródłowego

Kod źródłowy niedostępny lokalnie lub brak dostępu do pliku.

Co należy sprawdzić?

Sprawdź, czy dane wejściowe przekazywane do tej operacji mogą pochodzić z zewnętrznych źródeł i czy są rygorystycznie walidowane.

Jak naprawić problem?

Przenieś klucz do zmiennych środowiskowych lub bezpiecznego menedżera sekretów (np. os.environ['INTEGRATION_KEY']) i dodaj go do pliku .env.example.

Jak zweryfikować naprawę?

Zastosuj zalecenie (Przenieś klucz do zmiennych środowiskowych lub bezpiecznego menedżera sekretów (np. os.environ['INTEGRATION_KEY']) i dodaj go do pliku .env.example.) i ponownie uruchom kontrolę `ai-threat-lab`.

Ograniczenia analizy

Statyczna obserwacja częściowa; nie stanowi potwierdzonej podatności bez weryfikacji kontekstu.

Interpretacja AI (Google Gemini):

Zagrożenie nr 3: Obserwacja audytowa (unspecified)

Niski priorytet (P3)

Status ustalenia: Kandydat do weryfikacji | Lokalizacja: src/utils/checksum.py

Co wykryto?

Obserwacja audytowa (unspecified) — lokalizacja: src/utils/checksum.py. Dowód:

Dlaczego może to być niebezpieczne?

Analizator zgłosił obserwację dla reguły `unspecified` na podstawie dowodu: Wymaga przeglądu przez inżyniera w celu oceny wpływu w kontekście docelowego systemu.

Fragment kodu źródłowego

Kod źródłowy niedostępny lokalnie lub brak dostępu do pliku.

Co należy sprawdzić?

Sprawdź, czy dane wejściowe przekazywane do tej operacji mogą pochodzić z zewnętrznych źródeł i czy są rygorystycznie walidowane.

Jak naprawić problem?

Zastąp hashlib.md5 bezpiecznym algorytmem hashlib.sha256.

Jak zweryfikować naprawę?

Zastosuj zalecenie (Zastąp hashlib.md5 bezpiecznym algorytmem hashlib.sha256.) i ponownie uruchom kontrolę `ai-threat-lab`.

Ograniczenia analizy
Statyczna obserwacja częściowa; nie stanowi potwierdzonej podatności bez weryfikacji kontekstu.

Interpretacja AI (Google Gemini):

Doradcza interpretacja AI (Google Gemini)

Podsumowanie modelu:
Audytowany kod zawiera krytyczny punkt ryzyka związany z wykonaniem poleceń powłoki w module eksportu oraz wyciek danych uwierzytelniających. Wdrożenie rekomendacji zabezpieczy aplikację przed zdalnym przejęciem środowiska wykonawczego.

Ograniczenia analizy i elementy nieobjęte badaniem

Pozostałe ograniczenia zakresu

INFORMACJA

- Statyczna analiza offline nie śledzi przepływu danych w czasie wykonania programu.
- Tryb audytu offline zabrania wysyłania pakietów sieciowych do badanych hostów.
- Zewnętrzne skompilowane biblioteki C (.dll/.so) zostały pominięte.

Uwaga: Raport techniczny JSON (report.json) zawiera pełny rejestr wszystkich 3 pojedynczych zdarzeń i technicznych ograniczeń modułów.